

Auswertung: Anforderungstreue der BDD-Testsuite

Vollaudit aller 281 Szenarien der aktuellen Suite (42 Feature-Dateien, Working Tree inkl. ADR-18-Überarbeitung). Jedes Szenario wurde zweischsig bewertet:

- **Treue** — spiegelt das Szenario die Intention der referenzierten SRS-Anforderung? (treu / verengt / abweichend; „verengt (dokumentiert)“ = die Einschränkung ist als Deviation/Kommentar deklariert)
- **Assertion-Ehrlichkeit** — prüfen die Step-Implementierungen echtes Verhalten? (stark / dünn = Oberflächen-Checks wie HTTP-200/nicht-leer / hohl = Assertion kann das behauptete Verhalten nicht falsifizieren)

Begleitartefakte: `requirement-bdd-index.md / .csv` (Requirement→BDD, maschinell aus den in diesem Audit ergänzten `@DCS-...`-Annotationen), `bdd-suite-mapping-2026-06-25.md` (alt→neu), `../TRACEABILITY_SRS_BDD.md`.

1. Gesamtbild

Achse	Ausprägung	Anzahl	Anteil
Treue	treu	212	75 %
Treue	verengt (dokumentiert)	27	9 %
Treue	verengt	35	12 %
Treue	abweichend	7	2 %
Assertions	stark	212	75 %
Assertions	dünn	56	19 %
Assertions	hohl	13	4 %

Lesart: Rund vier Fünftel der Suite prüfen echtes Verhalten gegen die Anforderungsintention. „Verengt (dokumentiert)“ sind bewusste, deklarierte Deviations (z. B. QES-Descope, DID-Party-Semantik) — kein Qualitätsmangel, sondern nachvollziehbare Scope-Entscheidungen. Handlungsbedarf konzentriert sich auf die hohlen und einen Teil der dünnen Assertions (Abschnitte 2–3).

2. Hohle Assertions (Findings mit Handlungsbedarf)

Diese Szenarien können ihr behauptetes Verhalten nicht falsifizieren — sie wären auch bei defektem System grün:

Datei	Szenario	Befund
01_authentication_authorization/authentication_authorization.feature	Locked account cannot authenticate even with valid credential	Der When-Step 'I am authenticated with roles' (set_headers_for_roles) setzt context.requests_response NICHT; das abschliessende Then re-asserted die ALTE Denial-Response aus dem Given-Block. Damit das Szenario gruen wird, muss der OID4VP-Login sogar ERFOLGREICH sein (sonst RuntimeError) — das Gegenteil der Titelbehauptung 'cannot authenticate'.
03_contract_creation/contract_approval.feature	Automated compliance check during approval	'validates against regulatory frameworks' und 'compliance issues are flagged' asserten nur ('findings' in body OR body.did) — jede Approve-Response mit did besteht; einzig 'organizational policies' ist stark (APPROVE_CONTRACT-Audit-Event gepollt).
03_contract_creation/contract_creation.feature	Create contract from template	'a draft contract is generated' + DID sind stark; ABER 'metadata is auto-filled' ist eine OR-Kette (is_date(created_at) OR created_by!=" OR status!=" DRAFT") — contract.get('created_by') liefert None, None!=" ist True, die Assertion kann NIE fehlschlagen; 'creation is logged and traceable to the template version' prüft nur created_at-Existenz, weder Log noch Template-Version.
03_contract_creation/contract_negotiation.feature	Open draft contract for negotiation	'the negotiation interface is displayed' = 200+did; 'I can view all contract clauses' asserted NUR body.did — keine einzige Klausel wird gelesen.
03_contract_creation/contract_negotiation.feature	Propose redline edit to contract clause	BEKANNTER BEFUND bestätigt: 'the original text is preserved' asserted nur negotiations != [] (contract_workflow_steps.py step_then_original_text_preserved) — kein Originaltext wird verglichen; 'redline visible to other negotiators' ebenfalls nur Nichtleere der Liste, ohne Fremd-Identität.
08_audit_compliance/process_audit_and_compliance.feature	Auditor generates an audit report	Einzige Assertion: 'get http 200:Success code' — Report-Bytes/Inhalt/Format völlig ungeprüft.
08_audit_compliance/process_audit_and_compliance.feature	Compliance Officer submits a non-compliance incident report	Einzige Assertion: 200. Der Step-Kommentar des Nachbar-Steps dokumentiert, dass der Incident-Handler historisch ein No-op war — ein 200 auf {} beweist keinerlei Incident-Verarbeitung.
14_credential_acquisition/poa_credential_verification.feature	Signer presents a PoA credential proving delegated signing authority	Keine Step-Implementierungen fuer die Szenariotexte vorhanden (grep ueber steps/** leer); Szenario ist reiner dokumentierter Platzhalter.
14_credential_acquisition/poa_credential_verification.feature	A revoked PoA credential blocks signing	Keine Step-Implementierungen vorhanden; @skip.
19_c2pa_conformance/c2pa_conformance.feature	Verification succeeds from the remote manifest after the embedded attachment is stripped (@skip)	@skip, wird nicht ausgefuehrt; Inline-Kommentar benennt die zwei ehrlichen Nachweiswege (Go-Test mit gemocktem IPFS oder neuer Test-Seam).
19_c2pa_conformance/c2pa_conformance.feature	Replaced lifecycle banner is a documented gap, not a BDD result (@skip)	@skip, Szenario-Body ist nur der Auth-Given; assertiert absichtlich nichts.
21_pki_consolidation_pkcs11/pki_consolidation_pkcs11.feature	DCS_TRUST_ANCHORS switches the trust-anchor source for all verification layers (@skip)	Nur ein Given, keine Assertions — absichtlich, mit ausfuehrlicher Inline-Begrue ndung gegen ein False-Green.
22_real_signing_vertical/real_signing_vertical.feature	Signature Manager UI ceremony flow and AES badge - not provable from this HTTP-only BDD harness (@skip)	Nur ein Given, bewusst ohne Assertions, @skip.

3. Dünne Assertions (Nachschärfung empfohlen, nicht kritisch)

Datei	Szenario	Beleg
01_authentication_authorization/auth_and_access_control.feature	Public auth endpoint responds successfully (Outline)	Asserted nur HTTP 200 + Feld 'request_uri' nicht leer (assertion_steps.py step_then_response_json_includes); kein Format-/Inhaltscheck des request_uri.
01_authentication_authorization/auth_and_access_control.feature	Logout without a session is rejected	Asserted nur Status 401.
01_authentication_authorization/authentication_authorization.feature	Role enforcement prevents unauthorized actions	Asserted nur Status in (401, 403) — 401 (unauthenticated) und 403 (forbidden) werden nicht unterschieden.
02_template_management/create_template.feature	Unauthorized role cannot create template	Asserted nur Status in (401, 403).
02_template_management/generate_contract.feature	Generate contract from approved template	'a contract is created' asserted 200 + Contract-DID + Retrieve-Roundtrip (contract_workflow_steps.py:718), aber keinerlei Inhalts-/Terms-Pruefung des erzeugten Vertrags.
02_template_management/generate_contract.feature	Unauthorized role cannot generate contract	Asserted nur Status in (401, 403).
02_template_management/search_templates.feature	Search in template details	Suchtreffer stark asserted (1 Treffer + Name), aber 'I see the template provenance' akzeptiert IRGENDNEINES von created_at/created_by/updated_at als 'Provenance' (template_api_steps.py:147) — ein Zeitstempel ist kein Provenance-Nachweis.
02_template_management/search_templates.feature	Retrieve unauthorized	Asserted nur Status in (401, 403).
02_template_management/template_archive.feature	Deprecate an active template	Statuswechsel stark (Refetch, state==DEPRECATED); ABER der Guard-Probe-Call sendet {'did': did} an /contract/create, das 'template_did' erwartet (template_api_steps.py:221 vs. contract_workflow_steps.py:400) — der >=400-Check wuerde auch bei einem AKTIVEN Template gruen (Decoder-400), beweist also nicht die Deprecation-Sperre.
02_template_management/template_archive.feature	Unauthorized role cannot deprecate template	Asserted nur Status in (401, 403).
02_template_management/template_archive.feature	Unauthorized role cannot delete template	Asserted nur Status in (401, 403).
02_template_management/template_catalogue.feature	A role outside the catalogue scope cannot publish a template	'denied with a client error' akzeptiert 400/401/403/404/409/422 (contract_state_machine_steps.py:627) — ein 400-Validierungsfehler wuerde faelschlich als RBAC-Denial durchgehen.
02_template_management/template_identity.feature	Retrieve template by DID	'I receive the correct template' asserted nur body.did nicht leer (template_workflow_steps.py:654) — kein Abgleich, dass es das ERWARTETE DID/Template ist; 'correct' ist unbelegt (implizit nur ueber die URL).
02_template_management/template_provenance.feature	A role outside the template scope cannot retrieve provenance credentials	'client error' akzeptiert 400-422-Spektrum — nicht spezifisch 401/403.
02_template_management/template_workflow.feature	Reject reviewed template with reason	'the rejection reason is recorded' prueft NICHT die Begrueundung, sondern re-asserted nur state==REJECTED (template_api_steps.py:75-86) — der Reason-Text 'Missing compliance clause' wird nirgends verifiziert.
02_template_management/template_workflow.feature	Unauthorized role cannot approve	Asserted nur Status in (401, 403).

Datei	Szenario	Beleg
	template	
02_template_management/update_template.feature	Update an existing template as reviewer (name)	Assertion 'name enthaelt Standard NDA' waere auch OHNE wirksames Update wahr (neuer Name == alter Name).
02_template_management/update_template.feature	Unauthorized role cannot update template	Asserted nur Status in (401, 403).
03_contract_creation/contract_approval.feature	Track approval routing status	'completed approvals with timestamps' pollt SUBMIT_CONTRACT-Events mit created_at (stark), 'overall progress' prüft REVIEWED + Event-Typen (stark); aber 'I see pending approvals' asserted nur body.did (hohl).
03_contract_creation/contract_creation.feature	Created contract renders in both machine-readable and human-readable views	MR-View: 'contract_data' in contract; HR-View: name ODER description vorhanden — die HR-Sicht (PDF) wird in anderen Szenarien echt geprüft, hier nicht.
03_contract_creation/contract_creation.feature	Draft contract is editable and versioned	'a new version is created with timestamp and user attribution' prüft nur updated_at-Existenz — weder Versionszähler-Bump noch created_by-Attribution.
03_contract_creation/contract_format_review.feature	Validate machine-readable structure	'the schema validation passes' asserted nur contract_data ist nichtleeres dict; required fields/data types clientseitig auf 3 Felder geprüft.
03_contract_creation/contract_negotiation.feature	Add comment to contract clause	Attribution stark (created_by des letzten Eintrags); aber 'the comment includes a timestamp' prüft nur contract.updated_at, nicht den Timestamp des Negotiation-Eintrags.
03_contract_creation/contract_negotiation.feature	Approve proposed change during negotiation	'approval logged' stark (ACCEPTED-Decision im Log); aber 'the change is applied to the contract' asserted nur HTTP 200 (Inhalt der Änderung nicht verglichen) und 'a new version is created' asserted nur did-oder-id-Präsenz (hohl).
03_contract_creation/contract_negotiation.feature	View negotiation log	'approvals and rejections' stark (ACCEPTED und REJECTED beide gefordert); aber 'I see all comments and proposals' = nur body.did und 'I see the full audit trail' = updated_at ODER negotiations!=None — beide hohl.
03_contract_creation/contract_negotiation.feature	Submit contract for review after negotiation	'status changes to Under Review' akzeptiert SUBMITTED/UNDER_REVIEW/REVIEW UND NEGOTIATION — NEGOTIATION würde den behaupteten Übergang gerade nicht beweisen; 'routed to assigned reviewers' prüft nur, dass Reviewer-DIDs existieren (die schon bei Create angelegt wurden); 'submission is logged' = did-Präsenz (hohl).
03_contract_creation/contract_negotiation.feature	Only parties to contract can negotiate terms	Nur Positivpfad (autorisierter Negotiator kommentiert erfolgreich); der Negativfall (Nicht-Partei wird abgewiesen) fehlt in DIESEM Szenario — 'contract does not list this instance'-Given existiert in den Steps, wird hier aber nicht genutzt.
03_contract_creation/contract_negotiation.feature	Contract Creator and assigned Reviewers can negotiate	'negotiation actions are logged with reviewer identity' asserted nur body.did (hohl) — die Identität wird nicht gelesen (im Gegensatz zum starken Attribution-Step des Kommentar-Szenarios).
04_contract_signing/signature_validation.feature	Signature validation reports the EU DSS indication when a DSS instance is deployed (@skip)	@skip — kein ausgeführter Beweis in CI; ehrlich als Skip deklariert statt fake-grün.
07_contract_storage_security/archive_management.feature	Auditor retrieves the archive audit log	Nur 'non-empty list' asserted — kein Eintrag wird inhaltlich geprüft (Struktur/Chain-Prüfung liegt in Pack 08).

Datei	Szenario	Beleg
08_audit_compliance/c2pa_provenance_export.feature	C2PA manifest is appended as incremental update preserving base PDF	Weder Inkrementalität (xref-Update) noch Base-Layer-Erhalt (Byte-Vergleich gegen den Erst-Export aus dem Given) werden asserted, obwohl context.pdf_bytes den Erst-Export bereithält.
08_audit_compliance/process_audit_and_compliance.feature	Compliance Officer runs continuous monitoring	Nur checked_at + risks-Liste (auch leer ok) — die eigentliche Risikodetektion beweist das Schwesterszenario in 03.
12_system_based_contract_management/contract_lifecycle_via_api.feature	Contract metadata and history are queryable via API after the lifecycle completes	step_then_search_includes_contract prueft nur DID-Inklusion in der Suchantwort; keine Metadaten- oder History-Assertion.
12_system_based_contract_management/system_user_classes.feature	A System Contract Creator authenticates with its own client credentials	dcs_system_user_steps.py prueft nur 200 + access_token + JWT-Form (3 Segmente); keine Pruefung, was der Creator tatsaechlich darf.
12_system_based_contract_management/system_user_classes.feature	A System Contract Manager authenticates with its own client credentials	Nur Tokenerhalt und JWT-Form; keine Manager-Faehigkeitspruefung.
12_system_based_contract_management/system_user_classes.feature	A System Contract Signer may still verify signatures it cannot create	Nur 'get http 200' auf GET /signature/retrieve; kein Inhalt der Antwort geprueft.
16_other/frontend.feature	Accessing the frontend	frontend_steps.py: ein GET auf ../digital-contracting-service/ui/ plus generisches 'the response status is 200'; kein Inhalt, kein Titel, kein Asset geprueft.
16_other/prometheus_monitoring.feature	/metrics endpoint is exposed	core/assertion_steps.py step_when_internal_request + Status-200-Check; nicht einmal das Prometheus-Expositionsformat des Bodys wird geprueft.
17_peer_trust/two_instance_peer_trust.feature	An inbound PostPdf interaction consults the local policy endpoint before proceeding	'was consulted' prueft nur, dass /trust-pdp/last IRGENDEINEN Request-Body meldet — nicht korreliert mit dieser Interaktion (kein contractDID-Abgleich, kein Zaehler); im Step selbst als Einschränkung gegenüber der Stub-Vorversion dokumentiert.
17_peer_trust/two_instance_peer_trust.feature	An outbound ship consults the local policy endpoint before proceeding	Gleiche unkorrelierte Praesenz-Pruefung von /trust-pdp/last wie beim Inbound-Szenario.
17_peer_trust/two_instance_peer_trust.feature	The policy endpoint receives peerDID, agreementCredential, direction, contractDID, and targetState	Alle fuenf Pflicht-Keys + direction-Enum werden geprueft, aber nur am 'zuletzt empfangenen' Request — die Werte (insb. contractDID == DID dieses Szenarios) werden nicht abgeglichen.
18_odrl_soundness/odrl_soundness.feature	A contract with a violated ODRL constraint cannot be approved	step_then_approval_rejected_constraint_violated prueft nur non-200; der Ablehnungsgrund ('ODRL constraint') wird nicht im Response-Body verifiziert.
18_odrl_soundness/odrl_soundness.feature	A bare-Duty policy shape is rejected by structural validation	Nur non-200 auf das Policy-Update; der Ablehnungsgrund wird nicht geprueft.
20_contract_hierarchy_bundle_export/contract_hierarchy_bundle_export.feature	Template bundle export returns a ZIP with flat template artifacts only	Nur Content-Type application/zip und Abwesenheit von parents/-Eintraegen (dcs_bundle_export_steps.py:166) — kein Positiv-Assert, welche Template-Artefakte enthalten sein muessen.
20_contract_hierarchy_bundle_export/contract_hierarchy_bundle_export.feature	Contract bundle export honors RBAC like retrieval	dcs_bundle_export_steps.py:111-115: unauth_headers = 'Bearer invalid-token'; damit ist nur 401-Verhalten fuer ungueltige Tokens belegt, nicht die Rollenpruefung, die der Szenariotitel ('unauthorized role') verspricht.
21_pki_consolidation_pkcs11/pki_consolidation_pkcs11.feature	A correctly PKCS#11-configured backend is reachable and serves	Assertion ist ausschliesslich http 200 auf /.well-known/did.json; die Beweiskette 'erreichbar =>

Datei	Szenario	Beleg
	its HSM-backed DID document	hsm.Open() erfolgreich' ist nur ein dokumentiertes Argument, kein Test-Assert.
21_pki_consolidation_pkcs11/pki_consolidation_pkcs11.feature	The exported PDF's Contract-Lifecycle-VC proof is ECDSA/ES256, not Ed25519Signature2020	Reine Byte-Suche im PDF: 'Ed25519Signature2020' abwesend, 'es256'/'ecdsa' (case-insensitiv) irgendwo vorhanden (dcs_pki_consolidation_steps.py:163-174). Kein Parse des VC, keine Proof-Verifikation; der ES256-Treffer koennte auch aus dem C2PA-Manifest stammen.
21_pki_consolidation_pkcs11/pki_consolidation_pkcs11.feature	A full PDF export's embedded C2PA manifest declares COSE alg ES256, not EdDSA	Byte-Pattern-Suche \xa2\x01\x26 (ES256) bzw. \xa2\x01\x27 (EdDSA) im rohen PDF (dcs_pki_consolidation_steps.py:233-245). Die CBOR-Herleitung ist praezise dokumentiert, aber es ist kein CBOR/COSE-Parse und keine Signaturverifikation; 3-Byte-Muster koennen in Binaerdaten zufaellig auftreten.
21_pki_consolidation_pkcs11/pki_consolidation_pkcs11.feature	Revoking the dev signing certificate in the CRL flips a previously valid signature to invalid	Baseline- und Nachher-Assertion sind Substring-Matches ('revoked' + 'cert'/'crl') auf der findings-Liste; keine Zertifikats-/CRL-Pruefung. Der Vorher/Nachher-Flip ist immerhin ein realer Verhaltensunterschied.
21_pki_consolidation_pkcs11/pki_consolidation_pkcs11.feature	A historical signature made with the old HSM key keeps validating after rotation, while a new signature uses the new key	'still valid' ist nur Abwesenheit von Invaliditaets-Substrings in findings (dcs_pki_consolidation_steps.py:377-384) — keine Signatur-Reverifikation; die Key-Version-Unterscheidung liest das key_version-Response-Feld aus /signature/retrieve.
22_real_signing_vertical/real_signing_vertical.feature	Applying a signature produces a PDF with a cryptographically valid PAdES signature in the named AcroForm field	Titel behauptet 'cryptographically valid', die Steps pruefen nur /T-Feldname (Byte-Suche ASCII/UTF-16BE) und ByteRange-Struktur (Offsets, Luecke) — keine CMS-Signaturverifikation. Praezisionsgrenze ist im Modul-Docstring dokumentiert, der Szenariotitel ueberzeichnet dennoch.
22_real_signing_vertical/real_signing_vertical.feature	The PAdES signature declares SubFilter ETSI.CAdES.detached with a full embedded x5chain	SubFilter per Byte-Suche; 'x5chain' nur als Groessenheuristik (/Contents-Hexblob > 4000 Zeichen, dcs_real_signing_vertical_steps.py:538-570) — kein ASN.1-Parse, Grenze im Step selbst dokumentiert.
22_real_signing_vertical/real_signing_vertical.feature	The PAdES signature carries an RFC3161 timestamp from the configured TSA (PAdES-B-T)	Praesenz des DER-OID 1.2.840.113549.1.9.16.2.14 als Hex-Substring (dcs_real_signing_vertical_steps.py:573-586) — kein Token-Parse, keine TSA-Signaturpruefung.
22_real_signing_vertical/real_signing_vertical.feature	The signature record binds both the PDF hash and the JSON-LD content hash	Generische Spalten-Introspektion (Namensfragmente 'pdf_hash'/'content_hash' etc.) + Ungleichheit der Werte (dcs_real_signing_vertical_steps.py:670-702); es wird NICHT geprueft, dass die Hashes zu den tatsaechlichen PDF-/JSON-LD-Bytes passen.
22_real_signing_vertical/real_signing_vertical.feature	The verify side cross-checks the embedded signer binding against the signature record	Nur Negativ-Assertion: Abwesenheit von Failure-Markern ('pid verification failed' etc.) in den findings (dcs_real_signing_vertical_steps.py:792-804); das POSITIVE Cross-Check-Finding ('re-verified and cross-checked'), das der Tamper-Docstring benennt, wird nicht asserted.
22_real_signing_vertical/poa_at_signing.feature	A signatory with a Power of Attorney for their party signs and is compliant	Completed-Signing (SIGNED/ACTIVE) real, aber die PoA-Seite ist nur String-Filter auf compliance-findings ('power of attorney' abwesend, poa_at_signing_steps.py:86-90); kryptographisch wird kein PoA-Credential geprueft.

4. Abweichende Szenarien

Datei	Szenario	Notiz
01_authentication_authorization/authentication_authorization.feature	Multiple failed credential attempts trigger account lockout	Account-Lockout ist in der SRS nirgends gefordert (kein Treffer fuer lockout/failed attempts); getestet wird Produktverhalten ohne SRS-Anker — @DCS-UNMAPPED getaggt.
01_authentication_authorization/authentication_authorization.feature	Locked account cannot authenticate even with valid credential	Wie oben ohne SRS-Anker; zusaetzlich prueft das Szenario nicht, was der Titel behauptet.
02_template_management/template_archive.feature	Cannot delete deprecated template	Widerspricht dem TR-18-Wortlaut ('MUST allow a Template Manager to delete a deprecated template') direkt: das Szenario beweist, dass genau das VERBOTEN ist. Vertretbar als TR-17-Aufbewahrungspflicht (historical records), aber die Traceability-Matrix fuehrt es als TR-18-Beleg.
14_credential_acquisition/poa_credential_verification.feature	Signer presents a PoA credential proving delegated signing authority	@skip: der Issuer-Chain-Walk zu einem Trust-Anchor ist bewusst deferiertes Roadmap-Werk (SRS TBD-B, XFSC-PCM-Wallet nicht verfuegbar); PoA-Praesentation+Statuspruefung laufen laut Header suite-weit beim Login.
14_credential_acquisition/poa_credential_verification.feature	A revoked PoA credential blocks signing	@skip aus demselben Grund (chain-invalid vs. revoked braucht denselben Chain-Walk-Verifier); plain Revocation-Blocking ist laut Header in jedem Verify-Pfad live, hier aber nicht belegt.
19_c2pa_conformance/c2pa_conformance.feature	Verification succeeds from the remote manifest after the embedded attachment is stripped (@skip)	Die Kernforderung von C2PA-008 ('verifier MUST fetch remote if stripped') ist im Backend nicht implementiert (kein Fallback-Zweig, kein unabhaengig persistiertes Manifest-Artefakt) — Szenario dokumentiert das Soll und bleibt @skip.
19_c2pa_conformance/c2pa_conformance.feature	Replaced lifecycle banner is a documented gap, not a BDD result (@skip)	'Replaced' ist kein erreichbarer ContractState (transition.go) — Banner Nr. 5 von 6 aus C2PA-006 ist nicht herstellbar; als recorded deviation gefuehrt.

5. Assertion-Qualität je Feature-Datei

Datei	stark	dünn	hohl
01_authentication_authorization/auth_and_access_control.feature	7	2	0
01_authentication_authorization/authentication_authorization.feature	2	1	1
02_template_management/create_template.feature	1	1	0
02_template_management/generate_contract.feature	0	2	0
02_template_management/search_templates.feature	2	2	0
02_template_management/template_archive.feature	2	3	0
02_template_management/template_catalogue.feature	3	1	0
02_template_management/template_identity.feature	1	1	0
02_template_management/template_integrity_audit.feature	2	0	0
02_template_management/template_provenance.feature	1	1	0
02_template_management/template_update_notifications.feature	3	0	0
02_template_management/template_workflow.feature	10	2	0
02_template_management/update_template.feature	3	2	0
03_contract_creation/contract_approval.feature	7	1	1
03_contract_creation/contract_creation.feature	8	2	1
03_contract_creation/contract_format_review.feature	10	1	0
03_contract_creation/contract_negotiation.feature	4	6	2
03_contract_creation/contract_state_machine_refactor.feature	10	0	0
04_contract_signing/signature_validation.feature	7	1	0
05_contract_deployment/contract_deployment.feature	13	0	0
06_contract_lifecycle/contract_termination.feature	4	0	0
07_contract_storage_security/archive_management.feature	11	1	0
08_audit_compliance/audit_ui_archive_orce.feature	16	0	0
08_audit_compliance/c2pa_provenance_export.feature	4	1	0
08_audit_compliance/process_audit_and_compliance.feature	3	1	2
12_system_based_contract_management/contract_lifecycle_via_api.feature	1	1	0
12_system_based_contract_management/system_user_classes.feature	5	3	0
14_credential_acquisition/poa_credential_verification.feature	0	0	2
15_access_revocation/signature_revocation_state.feature	2	0	0
16_other/frontend.feature	0	1	0
16_other/prometheus_monitoring.feature	0	1	0
17_peer_trust/two_instance_peer_trust.feature	10	3	0
18_odrl_soundness/odrl_soundness.feature	5	2	0
19_c2pa_conformance/c2pa_conformance.feature	6	0	2
20_contract_hierarchy_bundle_export/contract_hierarchy_bundle_export.feature	11	2	0
21_pki_consolidation_pkcs11/pki_consolidation_pkcs11.feature	3	5	1
22_real_signing_vertical/multi_signer.feature	3	0	0
22_real_signing_vertical/oid4vp_document_retrieval.feature	2	0	0
22_real_signing_vertical/poa_at_signing.feature	3	1	0
22_real_signing_vertical/real_signing_vertical.feature	15	5	1
23_semantic_hub/semantic_hub.feature	10	0	0
24_contract_bundle_export/contract_bundle_export.feature	2	0	0

6. Annotation und Requirement→BDD-Export

Im Zuge dieses Audits wurde jedes Szenario mit der vollen SRS-ID annotiert (@DCS-FR-... / @DCS-NFR-... / @DCS-IR-... , additiv zu bestehenden Tags; nicht zuordenbare Szenarien tragen @DCS-UNMAPPED mit Begründung im Feature). Daraus wird der Index `requirement-bdd-index.md / .csv` maschinell erzeugt: 142 referenzierte Anforderungs-IDs, 4 Szenarien ohne SRS-Zuordnung. `behave --dry-run` bestätigt: alle 42 Dateien parsen fehlerfrei; die 11 undefined Steps sind ausschließlich deklarierte `@skip`-Platzhalter.

7. Empfehlungen (priorisiert)

1. **Hohle Assertions reparieren** (Abschnitt 2) — geringer Aufwand, hoher Glaubwürdigkeitsgewinn vor der eco-QA; insbesondere die Fälle, in denen ein Negativtest bei Erfolg grün würde (Lockout, deprecated-Template-Guard).
2. **TR-18-Widerspruch klären**: „Cannot delete deprecated template“ vs. SRS-Wortlaut „MUST allow ... delete“ — Produktentscheidung nötig, danach Szenario oder Matrix korrigieren.
3. **Traceability-Korrekturen**: DCS-FR-PACM-04-Zeile ist veraltet (per-access justification wird inzwischen feldgenau geprüft); CSA-21 kann auf E2E-verifiziert gehoben werden (separates E2E-Gutachten).
4. **Dünne Krypto-Assertions** dort vertiefen, wo Titel mehr behaupten als die Prüfung („cryptographically valid“ nur strukturell; CRL/Rotation über DB-Seams): entweder Assertions vertiefen oder Titel ehrlich machen.
5. **Redline-Semantik**: Textvergleich vor/nach Approve + Abruf als zweiter Negotiator ergänzen (FR-CWE-14/18).